Open in app ↗ Sign up Sign in

Medium Search

Ot Security + Hacking + Security + Information Security + Cybersecurity +

Getting Started with OT Security: The Attacker’s Mindset — Intro to OT Penetration Testing (Part 4)

5 min read · Dec 7, 2025


aravind0×7 Follow

Listen Share

Hey awesome ppl!

aravind0x7 this side, welcome back to the next chapter of our journey into Operational Technology (OT) security.

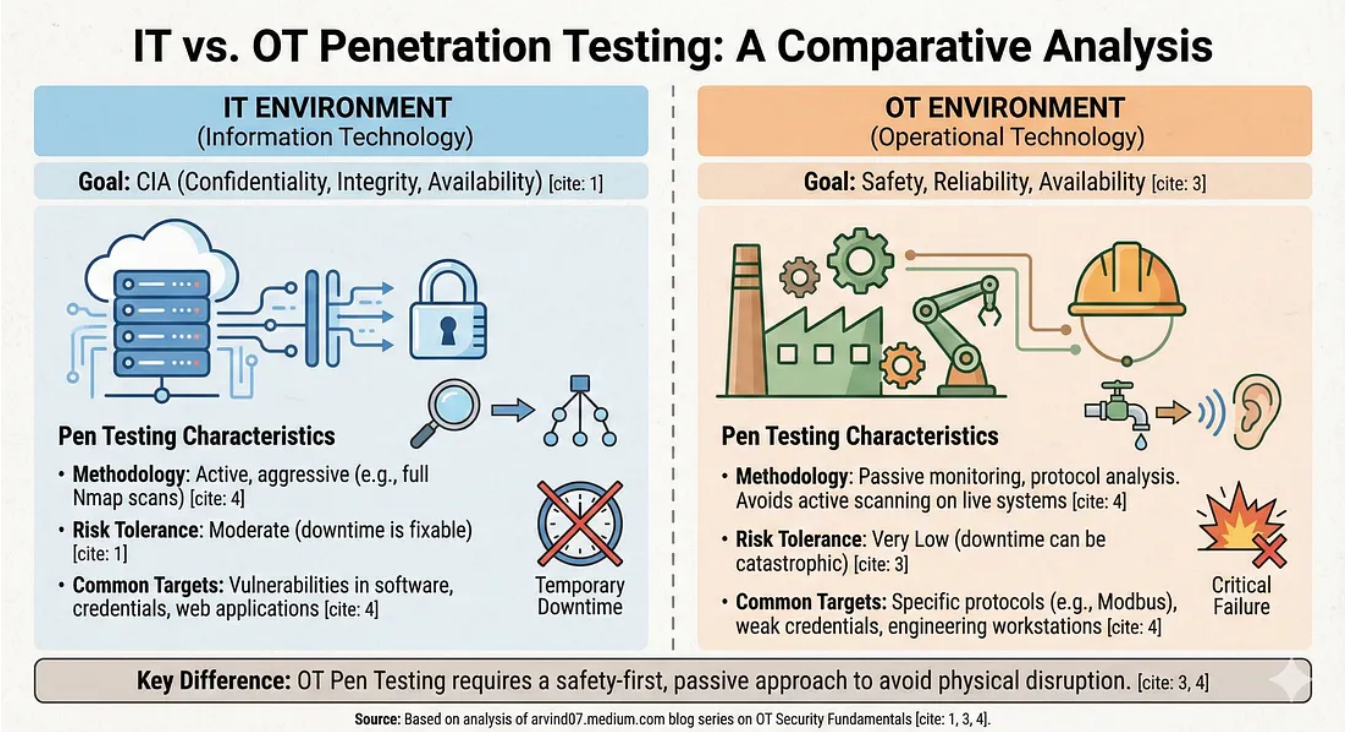


If you've been following along, you now know the fundamentals, understand why protocols like **Modbus** and **DNP3** are so insecure, and recognize the massive challenges presented by legacy systems and the IT/OT convergence. We've talked about threats; now, let's talk about how the bad guys (and the ethical ones!) actually operate.

Today, we're shifting our mindset from defense to offense. We're going to explore the critical differences between testing an IT network and an OT network, the methodology and the safe, surgical tools required to uncover vulnerabilities.

The Golden Rule: OT Pen Testing ≠ IT Pen Testing

Let's kick things off with the most important distinction. When you test an IT system, the worst-case scenario is usually a temporary outage or data loss. When you test an OT system, the worst-case scenario is an **unintended physical consequence.**



Crashing a **PLC** (Programmable Logic Controller) or a **DCS** (Distributed Control System) can lead to an explosion, the widespread loss of power, or contamination in a water facility.

Why Active Scanning is Dangerous

Traditional, aggressive IT scanning tools (like a full port sweep with Nmap or a comprehensive vulnerability scanner like Nessus) operate by flooding a system with unexpected packets. In the OT world, this is a recipe for disaster because:

1. **Legacy Systems Are Fragile:** Many older devices were never designed to handle unexpected data packets or traffic spikes. They lack the robust **exception handling** of modern computers and can enter a **fail-safe** state (which means shutdown) or, worse, an **uncontrolled state**.

2. **Unintended Commands:** An aggressive scan can be misinterpreted by a simple protocol like Modbus as a valid, physical command, causing an actuator to open or a pump to shut off mid-process.

3. **Availability is Life:** In the OT world, system availability is literally a matter of safety and continuity. Any test that compromises that is a failure, regardless of

the vulnerabilities found.

A imp thing to keep in mind !

> *You are testing against the **Safety, Reliability, and Availability (SRA)** model, not the traditional CIA model.*

Phase 1: Passive Reconnaissance (The Ghost Mode)

Since we can't crash anything, the first and most crucial phase of any OT assessment is **passive reconnaissance.** An attacker (or a good ethical hacker) sits quietly and listens. **The goal is to map the network architecture and control logic without transmitting a single malicious packet.**

1. Tapping the Wire and Protocol Analysis

Instead of actively scanning, the tester gains access to a monitoring port (a Span or Mirror port) on a switch carrying the OT traffic. We simply capture the data. This is where tools like **Wireshark** become the OT hacker's best friend.

Get aravind0x7's stories in your inbox

Join Medium for free to get updates from this writer.

Enter your email

Subscribe

Remember me for faster sign in

Because many OT protocols (like Modbus/TCP, Profinet, etc.) lack encryption, we can instantly learn an incredible amount of information:

- **Asset Inventory:** We can map the network hierarchy, identifying every single device, its IP address, its vendor, and even its function (e.g., "This is the Siemens PLC controlling Pump Station A").
- **Process Control Logic:** We can read the precise commands being sent and the data being received (e.g., "Write value 1 to register 40001" or "Tank level: 55%").

We effectively learn the **language of the factory**.

- **Identifying the Model:** By observing who talks to whom, we can trace communication paths and identify where the network segmentation (or lack thereof) exists between Level 3 (Control Servers) and Level 0/1 (PLCs/Field Devices).

2. External Footprinting

For initial reconnaissance, attackers often use tools like **shodan.com** (we will learn how to shodan in upcoming blogs). You can think of Shodan as a search engine for internet-connected devices. A simple search for common OT keywords or protocols can reveal:

- Exposed Human-Machine Interfaces (HMIs) directly connected to the internet.
- Control servers sitting outside the corporate firewall.
- Devices using default or easily guessable certificates.

If a critical device appears on Shodan, the attacker has already won the first and most difficult battle access.

Phase 2: Safe Active Testing & Critical Targets

Active testing is rare and must be surgical. It is generally restricted to a non-production **Test Bed** a duplicate environment designed to mimic the live system or conducted during a **scheduled maintenance window** with an OT engineer standing by.

The Test Bed: Your Lab of Horrors

A **Test Bed** is a crucial part of the safety methodology. By recreating the production environment (including the PLCs, HMIs, and protocols), security teams can safely run aggressive exploits and analyze the impact without any risk to the actual factory floor.

The Attacker's Favorite Targets

When an attacker moves to exploitation, they look for the low-hanging fruit and critical weaknesses:

1. **Weak or Default Credentials:** This remains the easiest path. Many legacy HMIs or even Engineering Workstations use default credentials or simple passwords like `admin/1234`. Once in, the attacker has operator-level access to the process.
2. **Firmware and Logic Flaws:** Attackers target the code that runs the devices. They look for vulnerabilities in the way PLCs handle code uploads (e.g., no digital signature required to upload new control logic) or exploit known, unpatchable flaws in the operating system running on the device.
3. **Engineering Workstations (EWs):** The EW is a critical pivot point. It holds the proprietary code for all PLCs. If an attacker compromises the EW via a simple IT vector (like a spear-phishing email), they can use that trusted machine to upload malicious code and sabotage the industrial process.
4. **Protocol Manipulation and Replay Attacks:** Because older protocols lack encryption and integrity checks, an attacker can:

- **MiTM:** Intercept a legitimate command (e.g., "open valve") and change the parameters (e.g., change the opening percentage).
- **Replay Attacks:** Capture a benign command packet and replay it later when it is detrimental to the process (e.g., replaying a "safe shutdown" command during maximum load).

Conclusion and What's Next

But theory is just the beginning. I know you're itching to see how this actually works in the real world.

In the next part of this series, we will dive into Practical OT Reconnaissance. We'll move away from the concepts and get our hands dirty (safely, of course!). I'll walk you through a step-by-step guide on how to perform reconnaissance against OT targets, demonstrating exactly how to capture traffic and identify assets without triggering alarms or breaking processes.

Follow me for more related stuff and connect with me via LinkedIn!

Ot Security + Hacking + Security + Information Security +

Cybersecurity +



Follow

Written by aravind0×7

2K followers · 29 following

Hacktivist | OT-ICS-IoT Researcher | Bug Bounty Hunter | Robotics and Automation Engineer